

ISO22301 in Simple English

Contents

0	Introduction.....	6
0.1	General.....	6
0.2	Benefits of a business continuity management system.....	6
0.3	The Plan-Do-Check-Act (PDCA) cycle.....	7
0.4	Contents of this document	7
1	Scope.....	8
2	Normative references	9
3	Terms and definitions	10
4	Context of the organization.....	11
4.1	Understanding the organization and its context.....	11
4.2	Understanding the needs and expectations of interested parties	11
4.2.1	General	11
4.2.2	Legal and regulatory requirements	11
4.3	Determining the scope of the business continuity management system	11
4.3.1	General	11
4.3.2	Scope of the BCMS.....	11
4.4	Business continuity management system	12
5	Leadership	13
5.1	Leadership and commitment.....	13
5.2	Policy.....	13
5.2.1	Establishing the business continuity policy	13
5.2.2	Communicating the business continuity policy	13
5.3	Roles, responsibilities and authorities	13
6	Planning.....	14
6.1	Actions to address risks and opportunities.....	14
6.1.1	Determining risks and opportunities	14
6.1.2	Addressing risks and opportunities	14
6.2	Business continuity objectives and planning to achieve them.....	14
6.2.1	Establishing business continuity objectives	14
6.2.2	Determining business continuity objectives	14
6.3	Planning changes to the business continuity management system	14
7	Support.....	15
7.1	Resources	15
7.2	Competence	15
7.3	Awareness.....	15
7.4	Communication	15
7.5	Documented information.....	15

7.5.1	General	15
7.5.2	Creating and updating	15
7.5.3	Control of documented information	16
8	Operation	17
8.1	Operational planning and control	17
8.2	Business impact analysis and risk assessment	17
8.2.1	General	17
8.2.2	Business impact analysis	17
8.2.3	Risk assessment	17
8.3	Business continuity strategies and solutions	18
8.3.1	General	18
8.3.2	Identification of strategies and solutions	18
8.3.3	Selection of strategies and solutions	18
8.3.4	Resource requirements	18
8.3.5	Implementation of solutions	19
8.4	Business continuity plans and procedures.....	19
8.4.1	General	19
8.4.2	Response structure	19
8.4.3	Warning and communication	20
8.4.4	Business continuity plans.....	20
8.4.5	Recovery	21
8.5	Exercise programme	21
8.6	Evaluation of business continuity documentation and capabilities	21
9	Performance evaluation	22
9.1	Monitoring, measurement, analysis and evaluation	22
9.2	Internal audit.....	22
9.2.1	General	22
9.2.2	Audit programme(s).....	22
9.3	Management review	22
9.3.1	General	22
9.3.2	Management review input	22
9.3.3	Management review outputs	23
10	Improvement	24
10.1	Nonconformity and corrective action	24
10.2	Continual improvement	24

Important Note

This document is intended as an unofficial but hopefully useful supplement to the ISO22301:2019 standard as published by the ISO. It is not recognized or endorsed by the ISO and they have not been involved in creating it. ISO22301 in Simple English is a rough translation from “ISO-speak” into a more digestible form of words that may help in understanding what the standard is getting at.

We strongly recommend you purchase a copy of the official ISO22301:2019 standard from an ISO-approved supplier and base your own interpretation of the standard around that.

Do not use this document as your only source of information about the requirements of the ISO22301:2019 standard.

This document is part of the CertiKit ISO22301 Toolkit which provides a complete documentation solution for organizations wishing to comply with the ISO22301:2019 standard.

For more details visit <http://www.certikit.com>.

Copyright notice

Except for any third-party works included in this document, as identified in this document, this document has been authored by CertiKit, and is ©CertiKit except as stated below.

CertiKit is a company registered in England and Wales with company number 6432088.

Disclaimer

Please Note: Your use of and reliance on this document template is at your sole risk. Document templates are intended to be used as a starting point only from which you will create your own document and to which you will apply all reasonable quality checks before use. Therefore, please note that it is your responsibility to ensure that the content of any document you create that is based on our templates is correct and appropriate for your needs and complies with relevant laws in your country. You should take all reasonable and proper legal and other professional advice before using this document. CertiKit makes no claims, promises, or guarantees about the accuracy, completeness, or adequacy of our document templates, assumes no duty of care to any person with respect its document templates or their contents, and expressly excludes and disclaims liability for any cost, expense, loss or damage suffered or incurred in reliance on our document templates, or in expectation of our document templates meeting your needs, including (without limitation) as a result of misstatements, errors and omissions in their contents.

Societal security – Business continuity management systems – Requirements

Foreword

ISO consists of technical committees which produce standards, and this one was created by number 292 which is Security and resilience. This 2019 version replaces the 2012 version and the following things have changed:

- The ISO format for such management system standards has been used
- Some requirements have been better explained, but no new ones added
- The business continuity content is now all in section 8 Operation
- Some of the terms have been clarified

0 Introduction

0.1 General

This International Standard tells you what to do to set up and run a good Business Continuity Management System (BCMS). How it works will depend on factors like what the organization does, how big it is, and the industry it is in.

A good BCMS

- Understands what's needed and why we need a policy and some objectives for business continuity management
- Allows us to manage better when things go wrong
- Checks its doing what it should
- Gets better over time

A BCMS has:

- A policy
- People who know what they need to do
- Ways of working about
 - Policy
 - Planning
 - Setting up and running
 - Measuring whether its working correctly
 - Reviewing the BCMS
 - Getting better
- Things written down that can be shown to an auditor

0.2 Benefits of a business continuity management system

A BCMS should help to keep things going if something bad happens. This is good because:

- For business:
 - Helps to achieve its purpose
 - Makes us better than the competition
 - Gives people confidence in us
 - Makes us more stable
- Financially:
 - We can stay legal
 - We could lose less money
- For other people:
 - Keeps others safe
 - Helps us do what they expect of us
 - Means they believe we can deliver

- Internally:
 - We can keep going
 - We manage our risks
 - We find weaknesses and deal with them

0.3 The Plan-Do-Check-Act (PDCA) cycle

Like many other standards, ISO22301 uses a model called “Plan-Do-Check-Act” (PDCA) which takes inputs, such as what’s needed, processes them and produces outputs that match what was needed.

Each of the clauses in this standard fits into either the Plan, Do, Check or Act part of the PDCA cycle.

0.4 Contents of this document

This standard uses the ISO high level structure so it fits in with other similar standards. If you want to show that you meet this standard you can:

- Just say that you do
- Get others such as customers to say that you do
- Get an external body to confirm that you do
- Become officially certified using a certification body

The requirements are in clauses 4 to 10. The meaning of some of the words used is as follows:

- “Shall” means you must
- “Should” means we think you ought to, but you don’t strictly have to
- “May” means you can if you want to
- “Can” means it’s possible, but we’re not saying you should or you shouldn’t

Where we say “NOTE”, we’re just trying to clarify what we mean.

1 Scope

This standard is about creating and running an BCMS within your organization, so that bad events happen less often but if they do happen, everyone will know what to do.

This standard is the same for all organizations, large and small and in any industry. How far you need to go with what it says, depends on what your organization does and how complicated it is.

You should use this standard if you want to:

- Set up, run and improve a BCMS
- Make sure business continuity policy is followed
- Keep things going when something bad happens
- Be able to cope with events better

You can also use it to work out how well you are doing business continuity at the moment.

2 Normative references

You need to read the following additional documents to understand this one:

ISO 22300, Security and resilience - Vocabulary

3 Terms and definitions

Where we use a particular word, this is what it officially means. If it says something different in ISO22300, use the definition we give in this document instead. Thirty-one words are defined in this section (not repeated here).

4 Context of the organization

4.1 Understanding the organization and its context

Think about how what happens outside and inside your organization affects your business and whether your BCMS can do what it needs to do. Consider these things when you're setting up and running your BCMS.

4.2 Understanding the needs and expectations of interested parties

4.2.1 General

When you create your BCMS, you need to find out

- Who has an interest in it
- What these people need

4.2.2 Legal and regulatory requirements

Create a procedure to make sure that you know, and write down, what laws and regulations you need to comply with when preparing for business continuity and take these into account when setting up and running your BCMS. Keep your knowledge up to date and tell everyone that needs to know.

4.3 Determining the scope of the business continuity management system

4.3.1 General

Work out what is and isn't covered by your BCMS then write it down. Don't forget to think about those things that happen inside and outside of your organization, those people with an interest in your business continuity we mentioned earlier in this section, and what your organization wants to, and has to, achieve.

4.3.2 Scope of the BCMS

You need to

- Say which parts of your organization are within scope of the BCMS

- Say which products, services and activities are covered by the BCMS

If you leave anything out of scope you need to say why, and you can't leave anything out that is needed for other areas within scope, or that is needed to provide business continuity.

4.4 Business continuity management system

Create, run and regularly improve an BCMS as described by this standard, including the processes mentioned.

5 Leadership

5.1 Leadership and commitment

The top management of the organization must show through their words and actions that they are behind the BCMS.

Top management need to show leadership regarding the BCMS by

- Making sure policies and objectives are set
- Making business continuity part of business as usual, not an add-on
- Providing the people, technology and other items needed to make the BCMS work
- Telling everyone how important business continuity is
- Making sure the BCMS does what is supposed to do
- Managing people to support the BCMS
- Telling everyone to keep improving the BCMS
- Helping other managers show commitment to the BCMS

5.2 Policy

5.2.1 Establishing the business continuity policy

Create a policy document(s) that makes sense and says clearly what you're trying to do (or at least how that will be defined). The policy should say that you will do what's needed to make your organization more resilient and will always try to make the BCMS better.

5.2.2 Communicating the business continuity policy

Make sure the policy is written down, then tell everybody about it, both inside and outside the company.

5.3 Roles, responsibilities and authorities

Make sure everyone involved in ensuring good business continuity knows what they have to do, including doing what this standard says and telling top management whether or not the BCMS is performing well.

6 Planning

6.1 Actions to address risks and opportunities

6.1.1 Determining risks and opportunities

Plan the BCMS and remember all the things that may happen inside and outside your organization that we mentioned earlier in section 4 and what the people with an interest in your business continuity might need.

Think about what could go wrong (or right) that would stop you achieving what you set out to do with your BCMS.

6.1.2 Addressing risks and opportunities

Do something about these risks and opportunities in advance. Adopt these actions into your normal way of working and check back that the things you did were successful.

6.2 Business continuity objectives and planning to achieve them

6.2.1 Establishing business continuity objectives

Decide what you're trying to achieve and how you'll know if you've achieved it. Check this ties in ok with your policies, the level of business continuity you think you need and what the relevant people said they needed. Write it all down, tell people about it and update it if things change.

6.2.2 Determining business continuity objectives

Don't forget the what, who, when and how within your plan.

6.3 Planning changes to the business continuity management system

If your BCMS needs to change, these changes need to be planned. Think about why you're making the change, how it affects the BCMS, whether you have enough resources, and what difference the changes make to who does what within your BCMS.

7 Support

7.1 Resources

Decide what you need to make the BCMS work and make sure these resources are available.

7.2 Competence

Assess what skills and experience people need to work in your BCMS and make sure they have it. If you have to provide training or take other actions to make them competent then check those actions worked and keep records of what has been done.

7.3 Awareness

Make sure everybody knows about the business continuity policy, why they need to follow it and what will happen if they don't. They also need to know what they should do if a disruptive incident happens.

7.4 Communication

Decide what messages you need to get across about the BCMS to people inside and outside your organization and then plan how you're going to do it, including the what, when, who and how.

7.5 Documented information

7.5.1 General

Make sure you have all of the documents this standard mentions as being needed and include any other information you feel helps.

7.5.2 Creating and updating

Create some standards for what information each document should display about itself and what format it should be in. Decide how you will store them and who will check and sign off each one.

7.5.3 Control of documented information

Make sure people can read documents they need, but keep them safe too. Decide how you're going to make them available and keep them so that they can be used properly. Record changes so that it's clear what's been changed and define what you will do with documents that are no longer in use. Label and look after useful information that comes from outside your organization.

8 Operation

8.1 Operational planning and control

Manage what needs to be done to achieve your objectives and your risks by

- Deciding how your processes should operate
- Controlling your processes
- Keeping appropriate records to show your processes are working

Make changes carefully and think about what to do when unexpected changes happen. If you get another organization to do things for you, make sure it's clear how that works.

8.2 Business impact analysis and risk assessment

8.2.1 General

Write down and use a process that allows you to decide how big a problem it would be if various events were to happen and how likely these are. Keep the business impact analysis and risk assessment up to date, especially when things change.

8.2.2 Business impact analysis

Create and implement a written process that works out what to recover first and to what extent.

Include

- What kinds of impact need to be considered
- The activities that help to produce or deliver the products and services
- How much worse the situation gets over time
- How long we have to recover the activities before it becomes a real problem
- Targets for getting things working again
- Which activities to focus on first
- What we need to recover the activities
- Who and what else we need to recover these activities

8.2.3 Risk assessment

Create and implement a written process that works out which risks to your business activities are the ones to really worry about.

This needs to

- Make a list of the risks that could lead to a disruption of anything that contributes to the important activities of the organization
- Decide how likely they are and what the impact would be if they happened
- Work out which ones need to have something done about them

8.3 Business continuity strategies and solutions

8.3.1 General

Once you've decided on a list of what could happen, how likely the risks are and what impact they would have, think about what approaches (or strategies) could be taken to provide business continuity before, during and after a bad event. Each approach will be made up of one or more parts (solutions).

8.3.2 Identification of strategies and solutions

Use the following criteria to decide whether the strategies and solutions are helpful. Do they:

- Allow you to recover when and how you need to
- Apply to the most important activities
- Lessen the impact
- Shorten the impact
- Protect our products and services
- Have enough resources to work

8.3.3 Selection of strategies and solutions

Choose the strategies and solutions that:

- Allow you to recover when and how you need to
- Are not too risky for your organization
- Are justified by the costs and benefits

8.3.4 Resource requirements

Once the strategies have been chosen, you need to think about what resources are needed to deliver them. These may include

- People
- Information and data
- Buildings and other physical resources
- Facilities, equipment and consumables
- Computer systems
- Transport
- Money
- Third parties, e.g. suppliers

8.3.5 Implementation of solutions

When you've chosen your solutions, get them ready so they can be used when needed.

8.4 Business continuity plans and procedures

8.4.1 General

Create a defined approach to be used if a disruptive incident happens, that tells the right people about it as soon as possible. Plans and procedures will show which solutions to use to address the situation, and these plans should be based on which strategies and solutions were chosen as being potentially useful.

The procedures shall

- Say what to do first
- Allow for changes in the situation
- Focus on the important activities first
- Use the right solutions to lessen the impact
- Say who should do what

8.4.2 Response structure

Define who will do what, in which teams, and who will report to whom when a disruptive event happens.

Together, the teams must be able to:

- Assess how bad the disruption is, or could be
- See if the event is bad enough to kick off a formal response
- Start taking action
- Plan what needs to be done
- Assess what needs to be done first

- Keep a good eye on what's going on
- Use the solutions available
- Talk to the right people at the right times

Make sure each team is defined and capable of taking action, using written procedures.

8.4.3 Warning and communication

Create procedures for

- How employees and other people with a relevant interest will talk to each other
- How to communicate with people outside your organization, including making use of any national or regional warning systems available
- How you will make sure communication is still possible even if your normal means is affected by the incident
- How you will deal with various authorities such as the emergency services
- How to talk to the media
- Recording who did what and when

You may also need to talk to people who have not yet been affected, and deal with more than one organization that is involved in helping. Make sure you test these procedures.

8.4.4 Business continuity plans

Write procedures that say how activities will be recovered within the time specified. They should be written to help teams do what they need to do.

These plans should include

- What to do to:
 - Keep the important things going or get them started again when they need to be
 - Keep an eye on the impact and what's being done about it
- When to activate the plans
- How to keep products and services being delivered to an agreed level
- What to do at first, so that people stay safe, things don't get worse and the environment is not affected

Each plan shall define

- What it is for and what it covers
- Who will do what
- What to do
- When it is to be activated and how

- How the plan relates to others, both internal and external
- What resources are needed
- How to communicate
- How to stop recovery activities if they are no longer needed

Make sure the plans are available where and when they might be needed.

8.4.5 Recovery

There should be procedures covering how to return to normal working after a plan has been put into action.

8.5 Exercise programme

You need to exercise and test procedures to make sure they work. The tests should

- Relate to the objectives set
- Be based on realistic situations and be clear about how to tell if they were successful
- Help people learn and get better at what they need to do
- Cover all areas over time
- Result in a written report that states what happened and what improvements can be made
- Be reviewed for improvement ideas
- Happen according to a defined schedule and when something major changes

Make sure you use the results of testing to improve the BCMS and the plans.

8.6 Evaluation of business continuity documentation and capabilities

You must:

- Check that all of your plans, procedures, strategies and solutions, and the business impact analyses and risk assessments they are based on, are correct and work well
- Use a number of different ways to validate your business continuity
- Check the business continuity capabilities of your partners and suppliers
- Every now and then check that you're still legal, using best practice and doing what you said you would in your policy
- Update your documentation as soon as you can

Plan these reviews regularly and when something big changes.

9 Performance evaluation

9.1 Monitoring, measurement, analysis and evaluation

You need to check that the BCMS is doing what it should. Work out how to tell if it is and decide who will do this and when. Define who will collect the information (and when) and who will check the information (and when) to make sure everything is ok. Make sure you keep records.

9.2 Internal audit

9.2.1 General

Get someone independent to check your BCMS regularly to see if you are doing everything this standard says and that it does what you need it to do.

9.2.2 Audit programme(s)

Write down when and how the audits will be done, making sure you cover the important areas first, based on risk assessments and previous audits.

Decide what each individual audit will cover and make sure that you will get a written report that you can read and keep. Management need to be told what the actions from the audit are and must take any required action as soon as possible.

The auditors should check that the actions from the last audit were done.

9.3 Management review

9.3.1 General

Top management will check the BCMS regularly to make sure it is working properly.

9.3.2 Management review input

Management reviews need to include

- Making sure you did what you said you would at the last review
- Changes that have happened recently both inside and outside your organization that might affect your business continuity

- How the BCMS is going, including:
 - Where you're up to with fixing issues previously found
 - Things you're measuring
 - Actions from audits and reviews
- Suggestions from various sources to improve the BCMS
- Any changes needed to the BCMS e.g. policy, objectives
- New ideas for the BCMS e.g. techniques or products
- Recent risk assessments and business impact analyses
- How recent tests went
- New or changed risks
- What was learned from recent incidents
- What you could do to make the BCMS better

9.3.3 Management review outputs

As well as deciding on ways to make the BCMS better and changes to it, the following should result from management reviews:

- BCMS scope changes
- Updates to documents such as risk assessment and business continuity plans
- Changes to procedures and controls to reflect what's happened within and outside the organization
- How you decide that a control is doing its job

Management reviews must be minuted and their results communicated to all relevant people. The organization needs to take the actions that were decided at the management reviews.

10 Improvement

10.1 Nonconformity and corrective action

If somebody finds something you're not doing right, you need to do something about it and fix what's happened. You also need to make sure it doesn't happen again by working out exactly what happened, what it affects, fixing it (but only if fixing it is cheaper or better than not fixing it) and then checking that it's definitely fixed, making sure you write down everything you did.

10.2 Continual improvement

Always try to make the BCMS better. Use the results of the other processes, such as analysis and evaluation and management review, to find things that can and should be improved.